Section 1 — Incident Header

Incident ID: INC-20260410-001
Date: 2026-04-10
Time Opened (IST): 08:40
Severity: High
Client: FinSecure Bank
Industry: BFSI (Banking, Financial Services, Insurance)
L1 Analyst: Arjun Mehta
L2 Analyst: Rohan Desai
L3 Analyst: Nisha Kapoor
Current Status: Open — Under Investigation
Sentinel Incident Number: 45721

Section 2 — Client & Environment Context

FinSecure Bank is a mid-sized private banking institution headquartered in Mumbai, with approximately 1,200 employees spread across its headquarters and three regional branch offices. The bank operates a mix of traditional retail banking services and a growing digital banking platform, making it heavily reliant on both on-premises and cloud-based infrastructure. Its customer base includes high-net-worth individuals and small-to-medium enterprises, meaning it holds a significant volume of sensitive financial and personally identifiable information (PII).

The bank operates a hybrid identity environment. Its on-premises Active Directory is synchronized with Azure Active Directory using Azure AD Connect, and all employee authentication ultimately flows through Azure AD. Multi-Factor Authentication is enforced across all accounts through Conditional Access policies, with stricter controls applied to privileged roles such as Global Administrators and Privileged Role Administrators. These high-privilege accounts are tightly monitored due to their ability to modify tenant-wide configurations, access sensitive systems, and bypass standard user restrictions.

The endpoint estate consists of approximately 950 Windows 10/11 workstations and 80 Windows Server 2022 systems, including domain controllers and application servers. Microsoft Defender for Endpoint is deployed across all assets, feeding telemetry into Microsoft Sentinel, which acts as the central SIEM platform for the bank's MSSP-operated SOC.

FinSecure also maintains an Azure footprint that includes production workloads such as customer-facing applications and backend databases hosted in Azure SQL. Access to these resources is governed through Azure AD roles and Privileged Identity Management (PIM).

From a compliance standpoint, the bank adheres to RBI IT Framework guidelines, PCI-DSS 4.0 for payment processing, and ISO 27001 standards. Any suspicious activity involving privileged accounts is treated with heightened urgency due to regulatory scrutiny and the potential for systemic impact.

At the time of this incident, there are no known active threats. However, privileged accounts remain a constant high-value target for external attackers attempting initial reconnaissance or credential compromise.

Section 3 — Attack Narrative (Attacker's Perspective)

The attacker began with a simple objective: identify valid credentials within FinSecure Bank's Azure AD tenant—preferably accounts with elevated privileges. Rather than attempting stealthy intrusion techniques, they opted for a direct and scalable approach: brute force authentication attempts against externally exposed login endpoints.

Using an automated script executed from a rented VPS, the attacker initiated a sequence of login attempts against the Microsoft online authentication portal. The tool was configured to cycle through a curated list of usernames gathered from prior reconnaissance—likely sourced from publicly exposed email formats, LinkedIn profiles, and leaked credential dumps. The attacker prioritized accounts that followed administrative naming conventions, such as "admin", "it.support", and role-based identifiers.

The script was tuned for speed within a constrained window. Over a span of five minutes, it executed repeated login attempts across three targeted accounts known—or strongly suspected—to hold privileged roles within the tenant. Each authentication request used a rotating password list, derived from commonly used enterprise passwords and slight variations designed to bypass simple lockout policies.

The attacker anticipated failures. In fact, failed logins were part of the strategy—to validate which accounts were active and responsive. The responses from the authentication endpoint provided subtle signals: differences in error messages, response timing, and account lockout behavior. These signals helped confirm that the targeted accounts were valid and actively in use.

Despite the aggressive attempt rate, none of the passwords successfully authenticated. However, that was not the immediate goal. The attacker was mapping the surface—identifying which accounts triggered lockouts, how quickly protections responded, and whether multi-factor authentication was enforced.

The external IP remained constant throughout the attack, intentionally avoiding distributed sources. This allowed the attacker to measure detection thresholds and understand how many attempts could be made before triggering security controls.

From the attacker's perspective, this was reconnaissance through pressure—probing the defenses to prepare for a more refined attack later.

Section 4 — Detection & Alert

At 08:40 IST, a new High severity alert surfaced in Microsoft Sentinel, triggered by the analytics rule titled **"Multiple Failed Logon Attempts — Threshold Breached."** The rule was designed to detect potential brute force activity against Azure AD accounts by identifying a high volume of failed authentication attempts within a short time window from a single source IP.

The rule logic was defined as follows:

```
SigninLogs
| where TimeGenerated > ago(5m)  // Focus on last 5 minutes
| where ResultType != 0  // Failed login attempts only
| summarize FailedAttempts = count() by IPAddress, UserPrincipalName
| where FailedAttempts >= 15  // Threshold condition
| summarize TotalFailures = sum(FailedAttempts), TargetedAccounts =
dcount(UserPrincipalName) by IPAddress
| where TargetedAccounts >= 3  // Multiple accounts targeted
```

The rule fired when a single external IP address — **185.243.115.47** — generated a concentrated burst of failed login attempts across three Azure AD accounts within a five-minute window.

Triggering Data Points:

- **IP Address:** 185.243.115.47
- **Total Failed Attempts:** 67
- **Targeted Accounts:**
  - admin.ops@finsecurebank.com
  - it.support@finsecurebank.com
  - pr.admin@finsecurebank.com
- **Time Window:** 08:34 – 08:39 IST
- **ResultType:** 50053 (Account locked) and 50126 (Invalid username or password)

In the Sentinel Incidents queue, the alert appeared with the following details:

- **Title:** Multiple Failed Logon Attempts — Threshold Breached
- **Severity:** High
- **Timestamp:** 08:40 IST
- **Entities:**
    - IP: 185.243.115.47
    - Accounts: admin.ops@finsecurebank.com, it.support@finsecurebank.com, pr.admin@finsecurebank.com
- **Status:** New
- **Incident ID:** 45721

On the central SOC display, the incident appeared in yellow, immediately below any Critical alerts. No audible alert was triggered, but its placement near the top of the queue made it visible to the L1 analysts within seconds.

Section 5 — L1 Triage (Arjun Mehta)

Arjun was about forty minutes into his morning shift. The initial rush of overnight alerts had already been cleared, and the Sentinel queue on his left monitor had settled into a manageable flow. He leaned slightly forward in his chair, scanning the queue top-down, eyes pausing briefly on each new entry.

At 08:40, a new High severity alert appeared at the top.

“Multiple Failed Logon Attempts…” he muttered under his breath, reading the title as he always did.

His mouse moved immediately. One click, and the incident panel expanded on his right monitor.

First glance — three accounts. He read them slowly.

“admin.ops… it.support… pr.admin…”

He paused. All three names had a pattern. Not regular users. He didn’t need to check the roles yet — the naming alone suggested privilege.

His eyes shifted to the IP address: **185.243.115.47**. External. No hostname resolution. Not internal traffic.

He leaned back slightly.

“Three accounts, same IP… five-minute window…”

He clicked into the incident details and scanned the alert description. Then his focus moved to the timestamp — 08:34 to 08:39. This wasn’t old. This had just happened.

Next, he opened the **Entity Behavior** tab for the first account — *admin.ops@finsecurebank.com*. The timeline populated with the last 24 hours of activity. He scanned quickly — normal sign-ins from Mumbai IP ranges earlier in the morning. Nothing unusual before this burst.

He switched to the **SigninLogs view** embedded in Sentinel and filtered for the same IP.

All failures.

He scrolled.

More failures.

He narrowed his eyes and added a quick filter for successful logins.

Nothing.

He sat still for a second, fingers hovering over the keyboard.

“Okay… no success,” he said quietly.

But something didn’t sit right.

He clicked into the second account. Same pattern. Third account — same again.

Then he noticed something in the ResultType column — **50053**. Account locked.

He straightened up.

“They actually hit lockout thresholds…”

That meant persistence. Not just a few attempts — sustained pressure.

He opened **Defender for Identity** briefly, just to confirm no correlated lateral movement or suspicious authentication patterns. Nothing yet.

He hesitated for a moment.

This could still be noise. Password spray attempts happen. But—

Three accounts. All likely privileged.

Lockouts triggered.

Same IP.

Five-minute burst.

He reached for his physical notepad and scribbled quickly:
“3x Priv accounts — brute? no success? lockout triggered”

He tapped the pen twice.

The key question was already answered — no successful login. But the intent was clear. And the targets elevated the risk.

He didn’t downgrade. If anything, this felt like early-stage reconnaissance.

He clicked into the **Incident comments** field and began typing, deliberately:

“Observed 67 failed login attempts from external IP 185.243.115.47 targeting 3 Azure AD accounts (admin.ops, it.support, pr.admin) within 5-minute window. No successful authentication observed. Multiple attempts resulted in account lockout (ResultType 50053). All targeted accounts appear to be privileged roles. Activity consistent with brute force or password spraying attempt.”

He paused, reread it once, then hit save.

Next, he opened **Microsoft Teams** on his secondary tab. The SOC-Incidents channel was already visible.

He began typing the escalation.

He didn’t rush it.

Every word mattered.

Escalation Message (08:46 IST):

[High Severity Escalation] — Potential Brute Force Attempt on Privileged Accounts

Alert: Multiple Failed Logon Attempts — Threshold Breached

Observations:

- 67 failed login attempts from single external IP (185.243.115.47)
- Targeted 3 Azure AD accounts: admin.ops, it.support, pr.admin
- All accounts appear to be privileged roles

- Multiple attempts resulted in account lockouts (ResultType 50053)
- No successful login observed during initial triage

Initial Assessment: Likely brute force/password spraying attempt targeting privileged accounts. No confirmed compromise yet, but intent appears focused.

Request: Need L2 validation on any post-lockout activity, MFA behavior, and geographic anomaly. Also confirm if IP has prior history in tenant.

He hit send. Then, without looking away from the screen, he pinged Rohan directly.

And waited.

Section 6 — L2 Investigation (Rohan Desai)

Rohan saw the Teams notification flash on his right monitor.

He didn't open Sentinel immediately.

Instead, he clicked into the SOC-Incidents channel and read Arjun's escalation carefully, line by line.

"Good," he murmured. "Clear thinking."

Three privileged accounts. Same IP. Lockouts triggered. No success — yet.

The word *yet* lingered.

He leaned forward and opened the Sentinel incident on his center monitor.

The investigation graph populated — one IP node connected to three user accounts. No additional entities yet. Clean, but telling.

He didn't touch the query window immediately.

Instead, he opened Notepad++ on his second monitor and typed:

// Q1: Did any successful login occur from attacker IP before or after failures?

// Q2: Was MFA triggered or bypassed?

// Q3: Any activity from targeted accounts post-lockout?

Only then did he switch to Log Analytics.

Query 1 — Authentication Outcome Analysis

```
SigninLogs
| where TimeGenerated between (datetime(2026-04-10 08:30:00) .. datetime(2026-04-10 09:00:00))  // Investigation window
| where IPAddress == "185.243.115.47"  // Attacker IP
| project TimeGenerated, UserPrincipalName, ResultType, ResultDescription, AuthenticationRequirement, MFAResult
| order by TimeGenerated asc
```

Result:

A clean sequence of failures.

- No ResultType 0 (success)
- Repeated **50126** (invalid credentials)
- Followed by **50053** (account locked)

MFAResult column remained empty — MFA was never triggered because primary authentication failed.

Rohan nodded.

“Good. They never got past the first gate.”

But he didn’t stop there.

Query 2 — Post-Lockout Activity Check

```
SigninLogs
| where TimeGenerated > datetime(2026-04-10 08:39:00)  // After attack window
| where UserPrincipalName in ("admin.ops@finsecurebank.com", "it.support@finsecurebank.com", "pr.admin@finsecurebank.com")
| project TimeGenerated, UserPrincipalName, IPAddress, ResultType, Location, DeviceDetail
| order by TimeGenerated asc
```

Result:

At 08:44 IST — a successful login.

Rohan froze for a second.

User: **it.support@finsecurebank.com**
IP Address: **49.37.182.21**
Location: Mumbai, India
ResultType: 0 (Success)

He leaned closer.

DeviceDetail showed a known corporate laptop. Compliant device.

He exhaled slowly.

“User probably unlocked account and logged back in.”

Still — timing mattered.

He cross-checked the IP reputation using AbuseIPDB on his third monitor.

- **185.243.115.47** — flagged, multiple reports, brute force activity
- **49.37.182.21** — clean, ISP-assigned Indian IP

No anomaly there.

Query 3 — IP History in Tenant

```
SigninLogs
| where IPAddress == "185.243.115.47"
| where TimeGenerated > ago(30d)
| summarize Attempts = count() by bin(TimeGenerated, 1d)
```

Result:

Zero prior activity.

“First contact,” he noted.

Investigation Conclusion

Rohan leaned back and reconstructed the sequence mentally.

This was not a compromise.

This was probing.

The attacker selected privileged accounts, applied pressure through rapid authentication attempts, triggered lockouts, and stopped.

No success.

No MFA interaction.

No lateral movement.

But the intent was precise.

Attack Timeline

Timestamp (IST)	Event	Data Source	MITRE Technique
08:34	Multiple failed login attempts begin from 185.243.115.47	SigninLogs	T1110 — Brute Force
08:36	Failures escalate across 3 privileged accounts	SigninLogs	T1110
08:38	Account lockouts triggered (ResultType 50053)	SigninLogs	T1110
08:39	Attack activity stops	SigninLogs	T1110
08:44	Legitimate user login post-lockout	SigninLogs	N/A

IOC Table

IOC	Type	Source	Enrichment Result
185.243.115.47	IP Address	SigninLogs	AbuseIPDB: High confidence brute-force source
admin.ops@finsecurebank.com	User	SigninLogs	Privileged account (Global Admin)
it.support@finsecurebank.com	User	SigninLogs	Privileged Role Admin
pr.admin@finsecurebank.com	User	SigninLogs	Privileged Role Admin

---

MITRE ATT&CK Mapping

- **T1110 — Brute Force (Credential Access)**

Containment Recommendations

Rohan switched back to Sentinel and began documenting.

Not generic. Specific.

1. **Block Attacker IP**
    - Add **185.243.115.47** to Conditional Access named location block list
    - Validate not present in VPN allowlist
2. **Force Password Reset**
    - Reset passwords for all three targeted accounts
    - Enforce strong password policy validation
3. **Review Account Lockout Policy**
    - Confirm lockout threshold and duration align with security baseline
4. **Enable Smart Lockout Enhancements**
    - Ensure Azure AD Smart Lockout is tuned for privileged accounts
5. **Audit Privileged Account Exposure**
    - Review naming conventions and external exposure of admin accounts
6. **Monitor for Follow-Up Attempts**
    - Create watchlist entry for attacker IP range
    - Increase alert sensitivity for privileged account authentication attempts

---

Rohan finished typing, then paused.

He added one final line to his notes:

"This is reconnaissance. Expect follow-up with more refined attack vectors."

He saved the investigation.

And marked the incident ready for L3 review.

Section 4 — Detection & Alert

At 08:40 IST, a new High severity alert surfaced in Microsoft Sentinel, triggered by the analytics rule titled **"Multiple Failed Logon Attempts — Threshold Breached."** The rule was designed to detect potential brute force activity against Azure AD accounts by identifying a high volume of failed authentication attempts within a short time window from a single source IP.

The rule logic was defined as follows:

```
SigninLogs
| where TimeGenerated > ago(5m)  // Focus on last 5 minutes
| where ResultType != 0  // Failed login attempts only
| summarize FailedAttempts = count() by IPAddress, UserPrincipalName
| where FailedAttempts >= 15  // Threshold condition
| summarize TotalFailures = sum(FailedAttempts), TargetedAccounts =
dcount(UserPrincipalName) by IPAddress
| where TargetedAccounts >= 3  // Multiple accounts targeted
```

The rule fired when a single external IP address — **185.243.115.47** — generated a concentrated burst of failed login attempts across three Azure AD accounts within a five-minute window.

Triggering Data Points:

- **IP Address:** 185.243.115.47
- **Total Failed Attempts:** 67
- **Targeted Accounts:**
  - admin.ops@finsecurebank.com
  - it.support@finsecurebank.com
  - pr.admin@finsecurebank.com
- **Time Window:** 08:34 – 08:39 IST
- **ResultType:** 50053 (Account locked) and 50126 (Invalid username or password)

In the Sentinel Incidents queue, the alert appeared with the following details:

- **Title:** Multiple Failed Logon Attempts — Threshold Breached
- **Severity:** High
- **Timestamp:** 08:40 IST
- **Entities:**
  - IP: 185.243.115.47
  - Accounts: admin.ops@finsecurebank.com, it.support@finsecurebank.com, pr.admin@finsecurebank.com
- **Status:** New
- **Incident ID:** 45721

On the central SOC display, the incident appeared in yellow, immediately below any Critical alerts. No audible alert was triggered, but its placement near the top of the queue made it visible to the L1 analysts within seconds.

Section 5 — L1 Triage (Arjun Mehta)

Arjun was about forty minutes into his morning shift. The initial rush of overnight alerts had already been cleared, and the Sentinel queue on his left monitor had settled into a manageable flow. He leaned slightly forward in his chair, scanning the queue top-down, eyes pausing briefly on each new entry.

At 08:40, a new High severity alert appeared at the top.

"Multiple Failed Logon Attempts…" he muttered under his breath, reading the title as he always did.

His mouse moved immediately. One click, and the incident panel expanded on his right monitor.

First glance — three accounts. He read them slowly.

"admin.ops… it.support… pr.admin…"

He paused. All three names had a pattern. Not regular users. He didn't need to check the roles yet — the naming alone suggested privilege.

His eyes shifted to the IP address: **185.243.115.47**. External. No hostname resolution. Not internal traffic.

He leaned back slightly.

"Three accounts, same IP… five-minute window…"

He clicked into the incident details and scanned the alert description. Then his focus moved to the timestamp — 08:34 to 08:39. This wasn't old. This had just happened.

Next, he opened the **Entity Behavior** tab for the first account — *admin.ops@finsecurebank.com*. The timeline populated with the last 24 hours of activity. He scanned quickly — normal sign-ins from Mumbai IP ranges earlier in the morning. Nothing unusual before this burst.

He switched to the **SigninLogs view** embedded in Sentinel and filtered for the same IP.

All failures.

He scrolled.

More failures.

He narrowed his eyes and added a quick filter for successful logins.

Nothing.

He sat still for a second, fingers hovering over the keyboard.

“Okay… no success,” he said quietly.

But something didn’t sit right.

He clicked into the second account. Same pattern. Third account — same again.

Then he noticed something in the ResultType column — **50053**. Account locked.

He straightened up.

“They actually hit lockout thresholds…”

That meant persistence. Not just a few attempts — sustained pressure.

He opened **Defender for Identity** briefly, just to confirm no correlated lateral movement or suspicious authentication patterns. Nothing yet.

He hesitated for a moment.

This could still be noise. Password spray attempts happen. But—

Three accounts. All likely privileged.

Lockouts triggered.

Same IP.

Five-minute burst.

He reached for his physical notepad and scribbled quickly:
“3x Priv accounts — brute? no success? lockout triggered”

He tapped the pen twice.

The key question was already answered — no successful login. But the intent was clear. And the targets elevated the risk.

He didn’t downgrade. If anything, this felt like early-stage reconnaissance.

He clicked into the **Incident comments** field and began typing, deliberately:

“Observed 67 failed login attempts from external IP 185.243.115.47 targeting 3 Azure AD accounts (admin.ops, it.support, pr.admin) within 5-minute window. No successful authentication observed. Multiple attempts resulted in account lockout (ResultType 50053). All targeted accounts appear to be privileged roles. Activity consistent with brute force or password spraying attempt.”

He paused, reread it once, then hit save.

Next, he opened **Microsoft Teams** on his secondary tab. The SOC-Incidents channel was already visible.

He began typing the escalation.

He didn’t rush it.

Every word mattered.

Escalation Message (08:46 IST):

[High Severity Escalation] — Potential Brute Force Attempt on Privileged Accounts

Alert: Multiple Failed Logon Attempts — Threshold Breached

Observations:

- 67 failed login attempts from single external IP (185.243.115.47)
- Targeted 3 Azure AD accounts: admin.ops, it.support, pr.admin
- All accounts appear to be privileged roles
- Multiple attempts resulted in account lockouts (ResultType 50053)
- No successful login observed during initial triage

Initial Assessment: Likely brute force/password spraying attempt targeting privileged accounts. No confirmed compromise yet, but intent appears focused.

Request: Need L2 validation on any post-lockout activity, MFA behavior, and geographic anomaly. Also confirm if IP has prior history in tenant.

He hit send. Then, without looking away from the screen, he pinged Rohan directly.

And waited.

Section 6 — L2 Investigation (Rohan Desai)

Rohan saw the Teams notification flash on his right monitor.

He didn't open Sentinel immediately.

Instead, he clicked into the SOC-Incidents channel and read Arjun's escalation carefully, line by line.

"Good," he murmured. "Clear thinking."

Three privileged accounts. Same IP. Lockouts triggered. No success — yet.

The word *yet* lingered.

He leaned forward and opened the Sentinel incident on his center monitor.

The investigation graph populated — one IP node connected to three user accounts. No additional entities yet. Clean, but telling.

He didn't touch the query window immediately.

Instead, he opened Notepad++ on his second monitor and typed:

// Q1: Did any successful login occur from attacker IP before or after failures?

// Q2: Was MFA triggered or bypassed?

// Q3: Any activity from targeted accounts post-lockout?

Only then did he switch to Log Analytics.

Query 1 — Authentication Outcome Analysis

```
SigninLogs
| where TimeGenerated between (datetime(2026-04-10 08:30:00) .. datetime(2026-04-10 09:00:00))  // Investigation window
| where IPAddress == "185.243.115.47"  // Attacker IP
| project TimeGenerated, UserPrincipalName, ResultType, ResultDescription, AuthenticationRequirement, MFAResult
| order by TimeGenerated asc
```

Result:

A clean sequence of failures.

- No ResultType 0 (success)
- Repeated **50126** (invalid credentials)
- Followed by **50053** (account locked)

MFAResult column remained empty — MFA was never triggered because primary authentication failed.

Rohan nodded.

“Good. They never got past the first gate.”

But he didn’t stop there.

Query 2 — Post-Lockout Activity Check

```
SigninLogs
| where TimeGenerated > datetime(2026-04-10 08:39:00)  // After attack window
| where UserPrincipalName in ("admin.ops@finsecurebank.com",
"it.support@finsecurebank.com", "pr.admin@finsecurebank.com")
| project TimeGenerated, UserPrincipalName, IPAddress, ResultType, Location, DeviceDetail
| order by TimeGenerated asc
```

Result:

At 08:44 IST — a successful login.

Rohan froze for a second.

User: **it.support@finsecurebank.com**
IP Address: **49.37.182.21**
Location: Mumbai, India
ResultType: 0 (Success)

He leaned closer.

DeviceDetail showed a known corporate laptop. Compliant device.

He exhaled slowly.

“User probably unlocked account and logged back in.”

Still — timing mattered.

He cross-checked the IP reputation using AbuseIPDB on his third monitor.

- **185.243.115.47** — flagged, multiple reports, brute force activity
- **49.37.182.21** — clean, ISP-assigned Indian IP

No anomaly there.

Query 3 — IP History in Tenant

```
SigninLogs
| where IPAddress == "185.243.115.47"
| where TimeGenerated > ago(30d)
| summarize Attempts = count() by bin(TimeGenerated, 1d)
```

Result:

Zero prior activity.

“First contact,” he noted.

Investigation Conclusion

Rohan leaned back and reconstructed the sequence mentally.

This was not a compromise.

This was probing.

The attacker selected privileged accounts, applied pressure through rapid authentication attempts, triggered lockouts, and stopped.

No success.

No MFA interaction.

No lateral movement.

But the intent was precise.

Attack Timeline

Timestamp (IST)	Event	Data Source	MITRE Technique
08:34	Multiple failed login attempts begin from 185.243.115.47	SigninLogs	T1110 — Brute Force
08:36	Failures escalate across 3 privileged accounts	SigninLogs	T1110
08:38	Account lockouts triggered (ResultType 50053)	SigninLogs	T1110
08:39	Attack activity stops	SigninLogs	T1110
08:44	Legitimate user login post-lockout	SigninLogs	N/A

IOC Table

IOC	Type	Source	Enrichment Result
185.243.115.47	IP Address	SigninLogs	AbuseIPDB: High confidence brute-force source
admin.ops@finsecurebank.com	User	SigninLogs	Privileged account (Global Admin)
it.support@finsecurebank.com	User	SigninLogs	Privileged Role Admin
pr.admin@finsecurebank.com	User	SigninLogs	Privileged Role Admin

---

MITRE ATT&CK Mapping

- **T1110 — Brute Force (Credential Access)**

Containment Recommendations

Rohan switched back to Sentinel and began documenting.

Not generic. Specific.

1. **Block Attacker IP**
    - Add **185.243.115.47** to Conditional Access named location block list
    - Validate not present in VPN allowlist
2. **Force Password Reset**
    - Reset passwords for all three targeted accounts
    - Enforce strong password policy validation

3. **Review Account Lockout Policy**
    - Confirm lockout threshold and duration align with security baseline
4. **Enable Smart Lockout Enhancements**
    - Ensure Azure AD Smart Lockout is tuned for privileged accounts
5. **Audit Privileged Account Exposure**
    - Review naming conventions and external exposure of admin accounts
6. **Monitor for Follow-Up Attempts**
    - Create watchlist entry for attacker IP range
    - Increase alert sensitivity for privileged account authentication attempts

---

Rohan finished typing, then paused.

He added one final line to his notes:

“This is reconnaissance. Expect follow-up with more refined attack vectors.”

He saved the investigation.

And marked the incident ready for L3 review.